

# Атрибути, ризик и периодични преглед приступа

Контекстуална контрола приступа и периодична процена  
ризика



# Садржај презентације

01

## Атрибути

Поуздан контекст уз стабилну улогу.

05–09

02

## Политика

Мала правила и разлог одбијања.

10–15

03

## Ризик

Преостала изложеност и SoD.

16–22

04

## Преглед

Потврда потребе и повлачење права.

23–30

## Увод

Контекстуална одлука и основни појмови (03–04).

## УВОД

# Контекстуална одлука о приступу

RBAC обезбеђује стабилну основу, док атрибути субјекта, ресурса и окружења прецизирају одлуку.

## ПРЕДМЕТ АНАЛИЗЕ

### Ризик који се анализира

RBAC даје стабилну основу, али сложеније одлуке често зависе и од контекста: припадности, врсте података, времена, стања ресурса или нивоа ризика. Атрибутска правила уводе тај контекст без претварања сваке могуће комбинације у нову улогу.

## ЗНАЧАЈ

### Значај за безбедност система

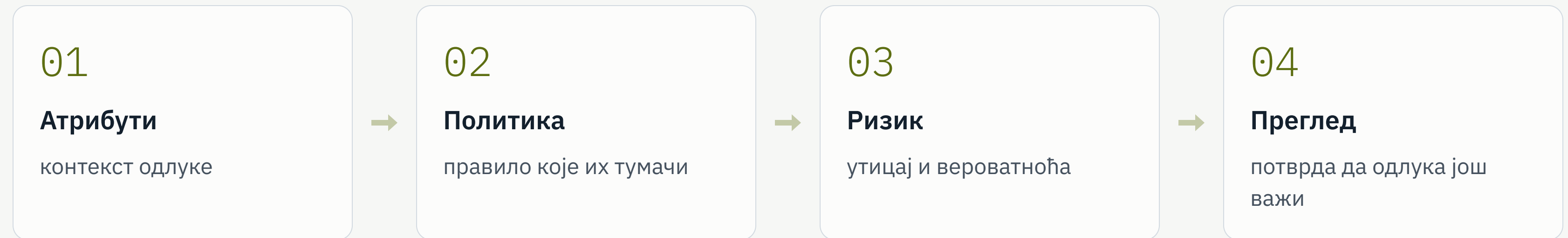
Risk register и редован преглед приступа спречавају да се старе одлуке претворе у трајне претпоставке. Они чине видљивим преостали ризик, власништво над њим и тренутак када одлуку треба преиспитати.

#### КРИТЕРИЈУМ ПРОВЕРЕ • Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

# Основни појмови

Атрибути, политика, ризик и периодични преглед одређују контекст и трајање права приступа.



## ЗАКЉУЧАК

Контекст даје прецизност одлуци, а редован преглед проверава да ли одлука и даље има смисла.

# 01

ПРВИ ДЕО

## Поуздани атрибути

Одлука спаја улогу са контекстом субјекта, ресурса, радње и окружења.

Субјект

Ресурс

Радња

Окружење

# Атрибути

контекст одлуке

01 Атрибути описују контекст захтева: улогу, уређај, локацију и процењени ризик.

Питање: који улаз покреће ову одлуку?

02 Атрибути се прикупљају из поузданих извора, а не из произвољног захтева клијента.

Питање: која граница мора бити видљива?

03 Контекст одлуке се бележи довољно да каснији преглед разуме исход.

Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

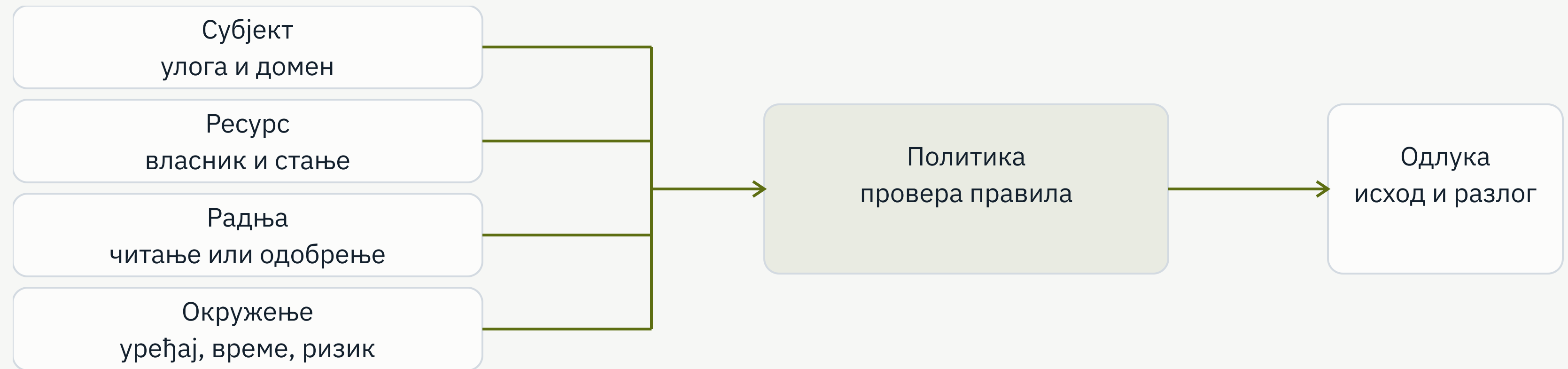
# RBAC и ABAC у истој одлуци

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

| Приступ     | Снага                                    | Ограничење                                       |
|-------------|------------------------------------------|--------------------------------------------------|
| RBAC        | Јасне, стабилне одговорности.            | Тешко изражава време, власништво и стање.        |
| ABAC        | Користи богат контекст одлуке.           | Тражи поуздане атрибуте и читљива правила.       |
| Комбинација | Улога даје основу, атрибути прецизирају. | Потребно је пажљиво објаснити приоритет правила. |
| SoD         | Спречава ризичне комбинације права.      | Мора се проверавати кроз ефективна права.        |

# Контекст атрибутске одлуке

Атрибути се процењују за конкретну радњу над конкретним ресурсом.



## Тумачење

Снимак контекста долази из познатих извора. Атрибут који клијент пошаље не постаје поуздан само зато што постоји у захтеву.

# Случај: иста улога, различит тренутак

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

## СЦЕНАРИО

### Пример: иста улога, различит тренутак

Два оператера имају исту улогу, али један ради на инциденту који му је додељен, док други ради на другом домену. Ако политика гледа само улогу, обојица би могла да одобре исту ризичну измену. Атрибути као што су припадност домену, стање инцидента и тренутно одобрење дају одлуци контекст који назив улоге сам не може да носи.

- 01 Атрибутска одлука остаје разумљива само ако је извор сваког атрибута познат и поуздан.
- 02 Правило треба да даје исти резултат за исти снимак контекста, како би могло да се тестира и објасни.
- 03 Преглед приступа враћа тим на питање да ли право и даље има пословни разлог, чак и када је некада било правилно додељено.

# 02

ДРУГИ ДЕО

## Политика као код

Мала правила дају предвидљив исход и разлог који се може проверити тестом.

Ред правила

Одбијање

Рок прегледа

# Политика

правило које их тумачи

**01** Политика је скуп малих правила, свако правило тумачи један атрибут.

Питање: који улаз покреће ову одлуку?

**02** Прво правило које одбије захтев одређује исход и његов разлог.

Питање: која граница мора бити видљива?

**03** Иста политика за исти контекст увек даје исти исход, па се може тестирати.

Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Која правила чине вашу политику и којим редом се проверавају?

# Атрибути прецизирају стабилну основу улоге

C# • илустративни пример

```
1  public AccessDecision Evaluate(  
2      AccessContext context, DateTimeOffset now)  
3  {  
4      var denial = _rules  
5          .Select(rule => rule.Evaluate(context))  
6          .FirstOrDefault(outcome => outcome is not null);  
7      return denial is null  
8          ? new(true, AccessDecisionCodes.Granted,  
9              "Atributi i rizik su prihvatljivi.",  
10             now + grantReviewInterval)  
11          : new(false, denial.Code, denial.Reason,  
12             now + denial.ReviewIn);  
13 }
```

## ТУМАЧЕЊЕ

Свако правило проверава један атрибут, прво одбијање одређује исход и рок следећег прегледа.

## БЕЗБЕДНОСНА ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

# Иста улога, супротан контекст, друга одлука

C# • илустративни пример

```
1  [Test]
2  public void
3      Evaluate_WhenRiskIsTooHigh_AsksWithEarlyReevaluation()
4  {
5      var decision = _policy.Evaluate(
6          Contexts.Safe with { RiskScore = 85 }, Now);
7      using (Assert.EnterMultipleScope())
8      {
9          Assert.That(decision.Code,
10             Is.EqualTo(AccessDecisionCodes.RiskTooHigh));
11          Assert.That(decision.ReviewAfter,
12             Is.EqualTo(Now.AddHours(1)));
13      }
14 }
```

## ДОКАЗ

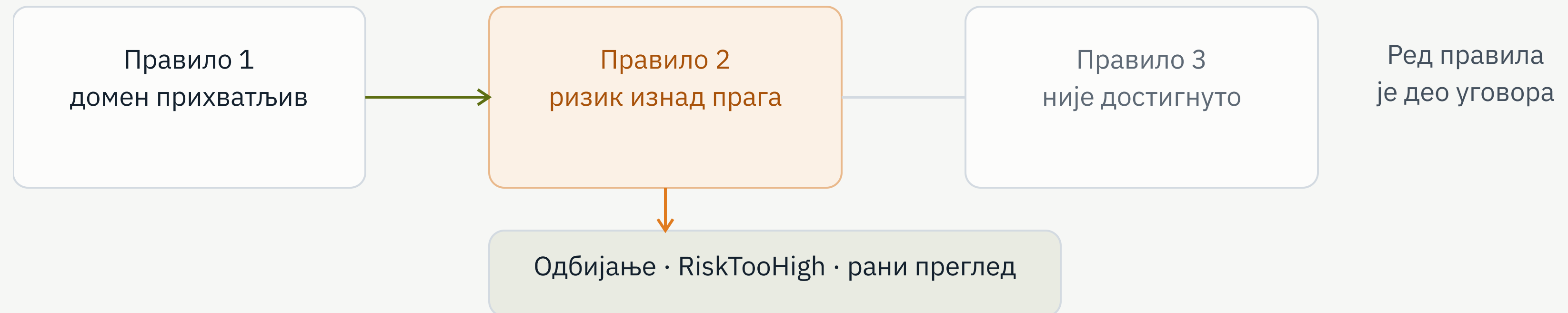
Тест мења само процену ризика и показује да се мењају и разлог и рок поновне провере.

## ОЧЕКИВАНИ ИСХОД

Тест мења једну чињеницу и очекује јасан, стабилан разлог одбијања.

# Прво одбијање у политици

Наставни пример користи први негативан исход у уређеном скупу правила.



## Тумачење

Ово је стратегија спајања правила у приказаном коду. Није опште правило свих ABAC система.

# Право приступа није заувек

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01 Атрибути се читају из поузданог, јасног контекста.

Јасно правило

02 Исто стање мора довести до истог резултата политике.

Проверљива примена

03 Ризик укључује имовину, претњу, контролу и преосталу изложеност.

Видљив доказ

# 03

ТРЕЋИ ДЕО

## Ризик и одговорност

Процена повезује имовину, сценарио, контролу и преосталу изложеност.

Risk register

Власник

Рок

SoD

# Ризик

утицај и вероватноћа

**01** Процењени ризик је атрибут одлуке: изнад прага приступ се одбија и поред исправне улоге.

Питање: који улаз покреће ову одлуку?

**02** Преостали ризик има власника који га прихвата на ограничено време.

Питање: која граница мора бити видљива?

**03** Регистар ризика чува сценарио, контролу, власника и датум следећег прегледа.

Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Који праг ризика у вашем систему мења одлуку и ко је одговоран за ту вредност?

# Од ризика до одлуке о прихватању

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

## КОНТЕКСТ

### Од ризика до одлуке о прихватању

Ризик се не уклања увек у потпуности. Неке мере би биле прескупе, неке би зауставиле важан рад, а неке зависе од спољне стране. Тада је важно да преостали ризик буде видљив, образложен и временски ограничен, а не заборављен.

- 01 Описати имовину, сценарио и последицу без општих формулација.
- 02 Навести постојеће контроле и шта оне заиста покривају.
- 03 Оценити шта остаје незаштићено након тих контрола.
- 04 Одредити власника који прихвата ризик и датум следећег прегледа.

# Контрола и преостали ризик

Прихвата се описана изложеност у познатом контексту.



## Тумачење

Прихватање ризика не замењује његово образложење. Промена имовине или контроле покреће нову процену.

# Запис у регистру ризика

JSON · илустративни пример

```
1  {  
2    "riskId": "R-17",  
3    "asset": "incident-report",  
4    "owner": "operations-director",  
5    "residualRisk": "medium",  
6    "acceptedUntil": "2027-01-31",  
7    "nextReview": "2026-12-15"  
8  }
```

## Повезан ревизиони траг

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

## НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

# Документовање одлуке засноване на ризику

Одлука бележи контекст, процену утицаја, преостали ризик и рок за поновни преглед.

## ОБРАЗЛОЖЕЊЕ

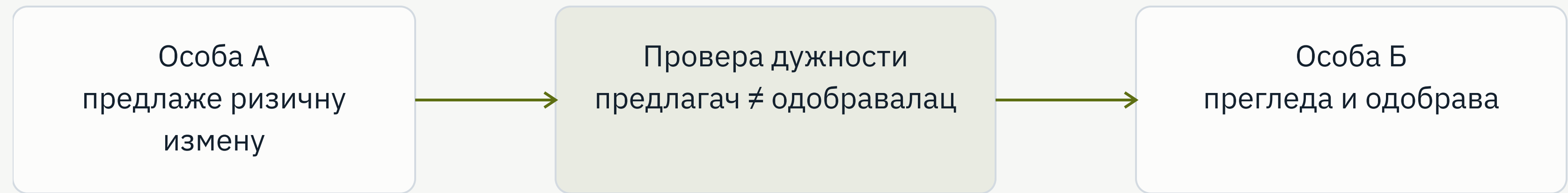
### Ризик као разговор о одлуци

Risk register није списак страшних сценарија. Он даје тиму заједнички начин да упореди утицај, вероватноћу, постојеће контроле и преосталу изложеност. Када се ризик прихвати, мора бити јасно ко га прихвата, зашто и када ће одлука бити поново прегледана.

- 01 Ризик повезује конкретну имовину, претњу и контролу.
- 02 Преглед приступа и преглед ризика имају ритам, власника и очекивани исход.
- 03 Сегрегација дужности спречава комбинације права које би једној особи дале превелику контролу.

# Сегрегација дужности

Илустративна контрола за радњу која захтева независно одобрење.



SoD се проверава над ефективним правима, укључујући наслеђена овлашћења.

## Тумачење

Сам назив улоге није довољан доказ раздвајања. Провера обухвата стварно доступне радње у целокупном току.

# 04

ЧЕТВРТИ ДЕО

## Периодични преглед

Право се потврђује док постоји потреба, а одлука оставља јасан траг.

Пословни разлог

Рок

Повлачење

Доказ

# Преглед

потврда да одлука још важи

01 Свака одлука носи рок следећег прегледа, одобрење не важи неограничено.

Питање: који улаз покреће ову одлуку?

02 Одбијање због високог ризика тражи ранију поновну процену него редовно одобрење.

Питање: која граница мора бити видљива?

03 Преглед приступа оставља запис ко је потврдио право и на основу чега.

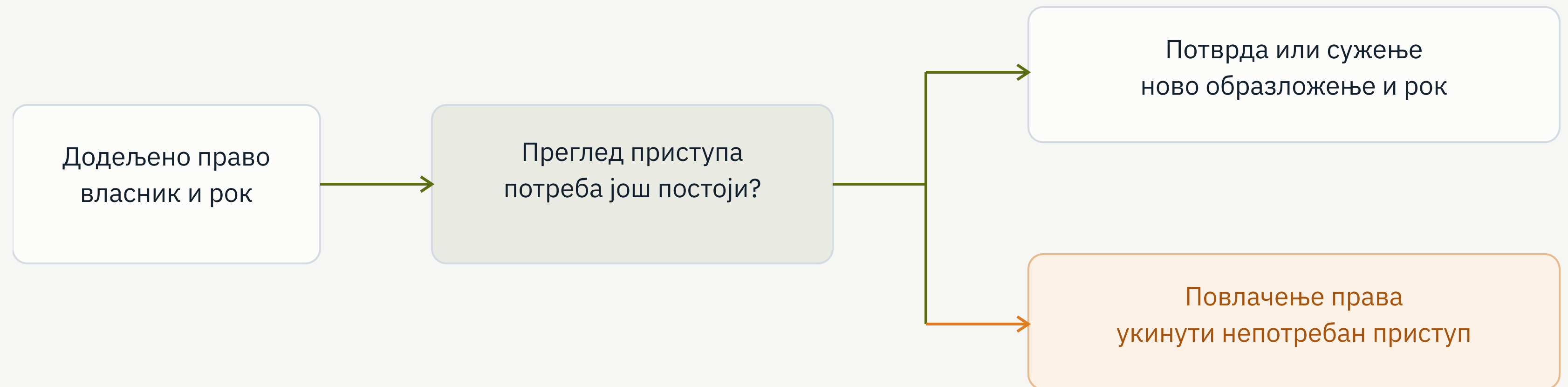
Питање: који доказ остаје после исхода?

## ПИТАЊЕ ЗА АНАЛИЗУ

Колико дуго у вашем систему важи одобрење пре него што се одлука поново провери?

# Исход прегледа приступа

Периодични преглед проверава актуелну потребу и садашњи контекст.



## Тумачење

Измена улоге, ресурса или ризика може захтевати ранији преглед. Запис бележи ко је одлуку потврдио и на основу чега.

# Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

## РАЗВОЈНИ КОНТЕКСТ

### Примена принципа у коду

Тим издваја одлуке које не могу поштено да стану у назив једне улоге. Затим их записује као правило које се може тестирати са неколико супротних контекста. Преглед приступа проверава да ли је некадашња пословна потреба и даље стварна.

01 Дефинисана одлука и њена граница.

02 Серверска имплементација провере.

03 Позитиван и негативан доказ.

# Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

---

**01** Увођење атрибута без јасног извора и значења.

Нема јасног власника одлуке.

---

**02** Правило које зависи од скривеног стања и даје необјашњив резултат.

Не постоји негативан сценарио.

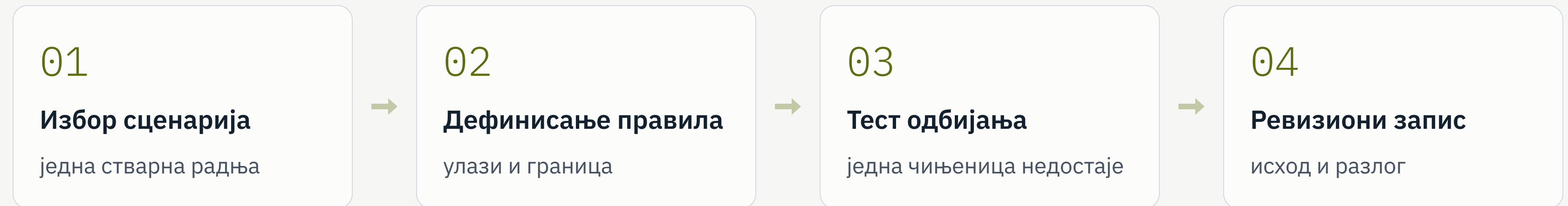
---

**03** Конфликт дужности откривен тек након што је штета могућа.

Доказ не показује стварни исход.

# Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

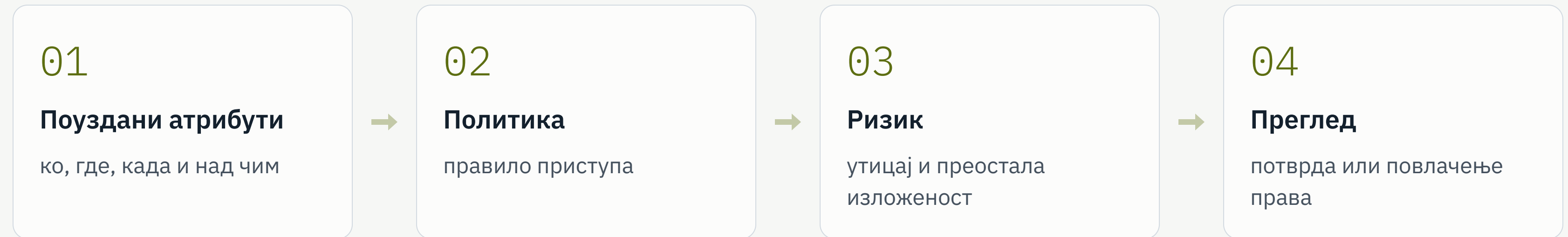


## ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Атрибути, ризик и периодични преглед приступа“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

# Модел контекстуалне одлуке

Контекст даје прецизност одлуци, а редован преглед проверава да ли одлука и даље има смисла.



## ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

# Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.

## Атрибути

контекст одлуке

## Политика

правило које их тумачи

## Ризик

утицај и вероватноћа

## Преглед

потврда да одлука још важи

**Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?**

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.